



CIBERSEGURIDAD EN ENTORNOS DE LAS TECNOLOGÍAS DE LA INFORMACIÓN

Bastionado de redes y sistemas

TEMA 6

Configuración de dispositivos y sistemas informáticos I
Alberto Diéguez Álvarez

Contenido

Dispones de los siguientes servicios y equipos:.....	3
Objetivo	3
Qué debes hacer	4
1. Segmentación lógica de red	4
2. Servicios expuestos en la DMZ	5
3. Migración de un servicio a la nube	6
4. Diseño de firewalls y control de flujos	6
5. Ubicación de componentes de seguridad	7
6. Diseño visual	9

¿Qué te pedimos que hagas?

La red de tu organización ha crecido de manera descontrolada y permite a usuarios y administradores acceder a recursos sin pasar por sistemas de control adecuados. Esto genera importantes riesgos de seguridad: flujos de red inseguros, accesos laterales innecesarios y exposición de servicios críticos.

Dispones de los siguientes servicios y equipos:

- Web corporativa con BBDD (gestión de stock)
- Gestor de contenidos web
- Servidor de directorio activo
- Servidor DNS
- Servicio de impresión
- Servidor de ficheros
- Portal del empleado (Intranet con fuentes externas)

Objetivo

Rediseñar la arquitectura de red de la organización para:

1. Asegurar los flujos de comunicación.
2. Proteger los servicios expuestos.
3. Minimizar la superficie de ataque.
4. Aplicar principios del modelo Zero Trust y segmentación de red.
5. Equilibrar seguridad con costes, considerando que solo hay 2 personas en el equipo de ciberseguridad.

Qué debes hacer

1. Segmentación lógica de red

- Define las VLANs necesarias para separar servicios, usuarios y zonas de red.
- Justifica cada VLAN indicando su función, nivel de exposición y por qué debe estar aislada.
- Incluye etiquetas de VLAN y subredes asignadas.

Primero pongamos la red, por ejemplo: **10.0.0.0/16**

The screenshot displays the ITPNetworks website. The main content area features a table with network configuration details for the 10.0.0.0/16 network. The table includes fields for Network Address, Usable Host IP Range, Broadcast Address, Total Number of Hosts, Number of Usable Hosts, Subnet Mask, Wildcard Mask, Binary Subnet Mask, IP Class, CIDR Notation, and IP Type. To the right of the table is a sidebar with a user profile for Alberto Dieguez Alvarez, including a profile picture, name, email, and a list of course details and access activity.

Field	Value
Network Address:	10.0.0.0
Usable Host IP Range:	10.0.0.1 - 10.0.255.254
Broadcast Address:	10.0.255.255
Total Number of Hosts:	65,536
Number of Usable Hosts:	65,534
Subnet Mask:	255.255.0.0
Wildcard Mask:	0.0.255.255
Binary Subnet Mask:	11111111.11111111.00000000.00000000
IP Class:	B
CIDR Notation:	/16
IP Type:	Private

- **VLAN 10: Usuarios**
 - **Subred:** 10.0.10.0/24
 - **Función:** Serían los PCs de los empleados
 - **Exposición:** Baja, es decir, solo que solo sea accesible desde redes internas.
 - **Justificación:** Se busca aislar a los usuarios para evitar conexiones externas.
- **VLAN 20: Servidores**
 - **Subred:** 10.0.20.0/24
 - **Función:** Se encargan de los servicios: DNS, Impresión, Directorio Activo...
 - **Exposición:** Baja
 - **Justificación:** Es donde están los servicios mas valiosos de la empresa, y solo deben ser accesibles desde las VLANs autorizadas.
- **VLAN 30: DMZ Web**
 - **Subred:** 10.0.30.0/24
 - **Función:** Página Web, portal de empleado...
 - **Exposición:** Alta
 - **Justificación:** Tiene servicios expuestos.

- **VLAN 40: DMZ Web**
 - **Subred:** 10.0.40.0/24
 - **Función:** Bases de datos.
 - **Exposición:** Baja
 - **Justificación:** Es donde se almacenan todos los datos de la empresa, nunca debe estar expuesta y solo accesible por unos puertos concretos.
- **VLAN 50: Administración**
 - **Subred:** 10.0.50.0/24
 - **Función:** Acceso de administradores a servidores web
 - **Exposición:** Muy Baja
 - **Justificación:** En esta parte se aplicaría Zero Trust y limitar el acceso con demasiados privilegios, lo suyo sería aplicar VPN y doble factor de autenticación
- **VLAN 60: Servicios externos**
 - **Subred:** 10.0.60.0/24
 - **Función:** Sería la salida a fuentes externas, deberá ser controlada
 - **Exposición:** Media
 - **Justificación:** Como es la salida a internet, se debe evitar que los servidores internos accedan libremente a Internet.

2. Servicios expuestos en la DMZ

- **Identifica qué servicios deben estar en la zona desmilitarizada (DMZ).**
- **Justifica su colocación según riesgos y necesidades de acceso desde internet o zonas no seguras.**

Servicios expuestos en la DMZ:

1. Web

Tiene que tener acceso desde internet. Tienen un riesgo alto ya que la información viaja por red externa (HTTP/HTTPS). Si se comprometen, no se debe dar acceso a la red interna.

2. Portal de empleado

Es accesible desde fuentes externas, entonces tiene un riesgo alto y si se comprometen se debe tener los usuarios externos separados de los servicios internos, es decir limitar el acceso desde el exterior para minimizar riesgos.

3. CMS (Content Management System) gestor de contenido

La web publica contenido hacia la web. Tienen un riesgo alto, ya que ha habido numerosos casos de hacking web históricamente. Y en caso de ser comprometida, hay que limitar el espacio al que se tiene acceso.

3. Migración de un servicio a la nube

- **Elige uno de los servicios y plantea cómo podría estar en una infraestructura cloud pública o híbrida.**
 - **Justifica la elección.**
 - **Indica medidas de seguridad necesarias (cifrado, autenticación, integridad, acceso VPN, etc.).**

Como servicio escogido he elegido la Web y el CMS:

Como tipo de nube he elegido pública.

Y mi justificación es que este es el servicio mas expuesto ya que está expuesto a internet. Al mover la web a un entorno cloud, estamos reduciendo el ataque interno.

También aislamos internet del servidor interno y tenemos menor impacto de ataque.

Como medidas de seguridad pondría las siguientes:

- Cifrado HTTPS
- Cifrar los discos duros y los backups
- Métodos de autenticación fuerte, es decir MFA y los usuarios con roles mínimos
- Acceso a la Base de Datos solo por VPN

Con todos estos métodos y la migración reducimos el ataque interno y a reducir costes.

4. Diseño de firewalls y control de flujos

- **Indica cuántos firewalls implementarías y su ubicación.**
- **Describe qué flujos controlarían (nivel de red).**
- **Para cada firewall, indica al menos una regla IPTABLES o ACL con este formato:**
- **IP origen - IP destino - puerto - protocolo – acción**

Implementaría **2 firewalls**:

- **Firewall perimetral**, es decir entre Internet y DMZ (Zona desmilitarizada), para controlar el acceso desde redes no fiables.

Un ejemplo de una regla IPTABLES sería:

IP origen	IP destino	Puerto	Protocolo	Acción
0.0.0.0/0	10.0.30.10	443	TCP	Permitir

Con esta regla permitimos el tráfico HTTPS desde una red externa a la DMZ

- **Firewall Interno**, es decir entre DMZ (Zona desmilitarizada) y la red interna, para que un compromiso en la zona DMZ no pueda acceder al interior.

Un ejemplo de una regla IPTABLES sería:

IP origen	IP destino	Puerto	Protocolo	Acción
10.0.30.10	10.0.40.10	3306	TCP	Permitir

Con esta regla permitimos el tráfico entre el DMZ y la Base de datos interna.

Y un ejemplo de DENY sería:

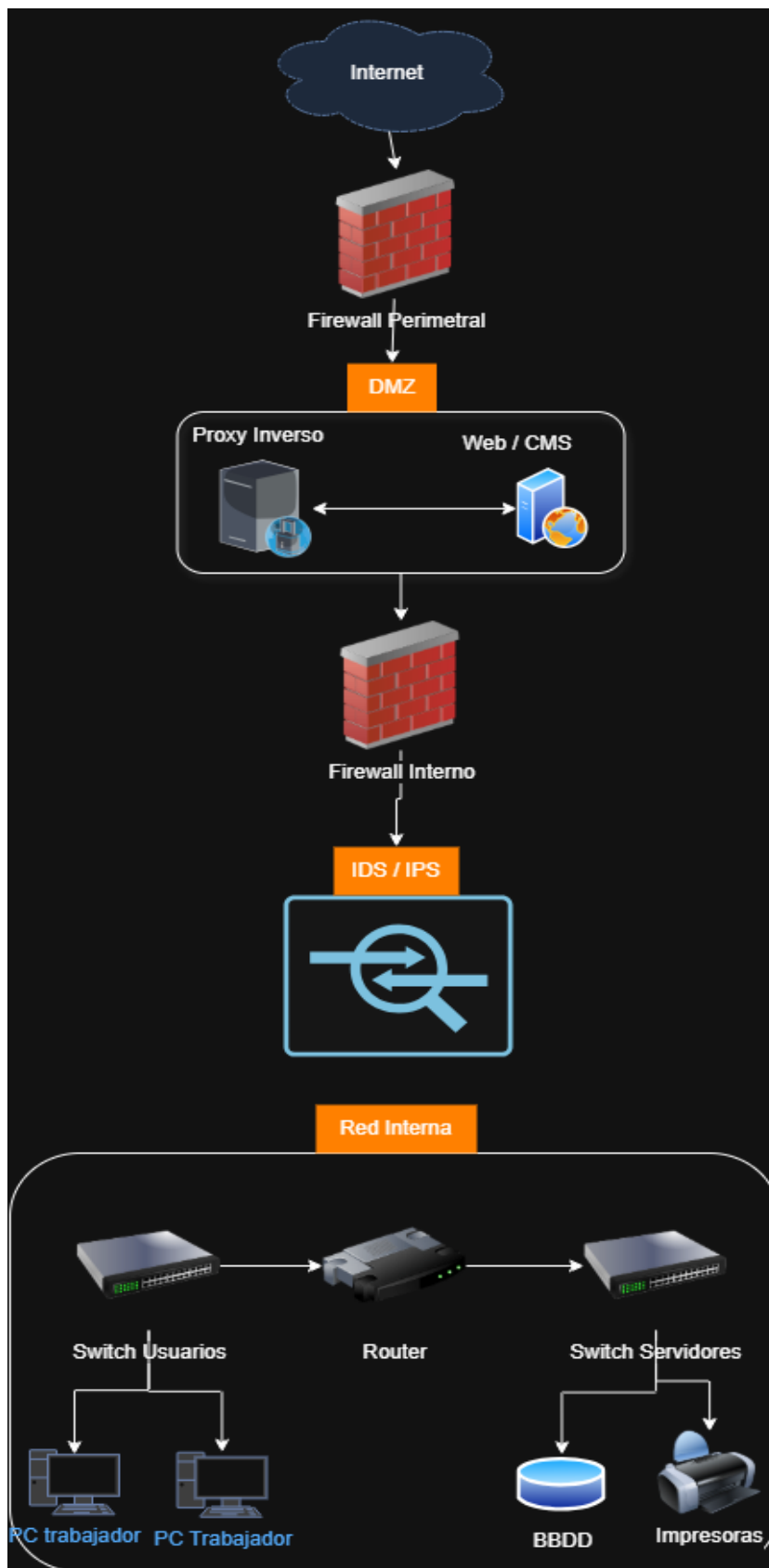
IP origen	IP destino	Puerto	Protocolo	Acción
10.0.30.0/24	10.0.20.0/24	ANY	ANY	Denegar

Con esta regla denegamos el acceso de un rango de IPs del DMZ a nuestros servidores.

5. Ubicación de componentes de seguridad

- **Dibuja en el diagrama y justifica la ubicación estratégica de:**
 - Switches
 - Routers
 - Firewalls
 - Proxys
 - IDS/IPS

He hecho este diagrama en Draw.io:

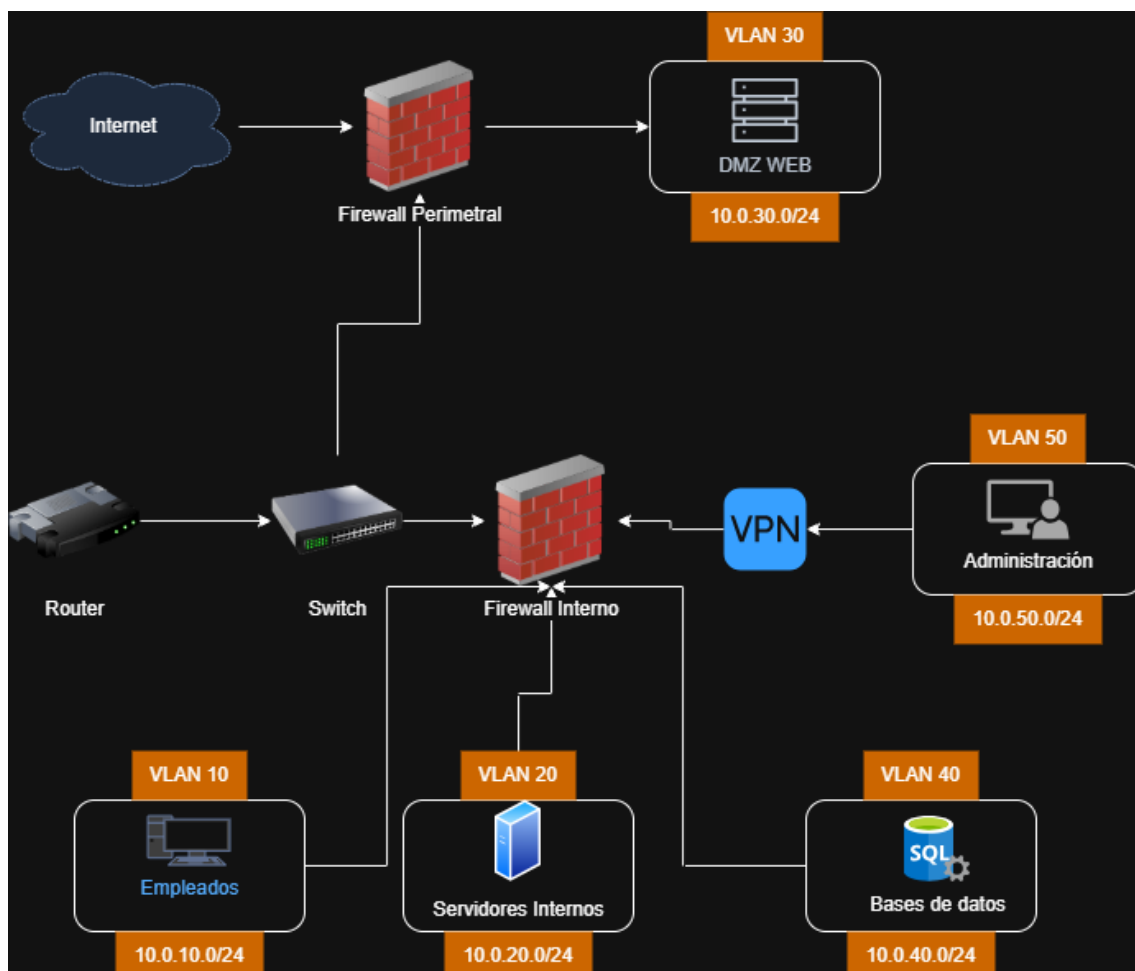


<https://drive.google.com/file/d/1Xw16PgoWj7eQTrGeoedZ5brYhPY0ibc1/view?usp=sharing>

6. Diseño visual

- Representa todo el diseño en un diagrama de red completo, claro y con leyenda.
- Puedes usar herramientas como Draw.io, Lucidchart, Canva, o incluso hacerlo a mano si está escaneado y legible.
- El diagrama debe mostrar:
 - Segmentación por VLANs
 - Servicios en DMZ
 - Zona interna
 - Zona de empleados
 - Servicios en la nube (si los hay)
 - Dispositivos de red y seguridad

He tenido bastantes dudas de como hacerlo, lo he hecho con la interpretación que creo que es correcta, pero seguro que algo me falta por ponerlo correctamente.



<https://drive.google.com/file/d/1Fi83xVJ726Z-6EWc2Z4vMtkcbdbZngCL/view?usp=sharing>

NOTAS:

- https://www.cisco.com/c/es_mx/solutions/small-business/resource-center/networking/how-to-set-up-a-network.html#~consejos-para-el-%C3%A9xito
- <https://ccnadesdecero.es/ejemplo-diagrama-red-domestica/>
- <https://edraw.wondershare.es/network-diagram-examples.html>
- <https://gitmind.com/es/que-es-diagrama-de-red-y-como-hacerlo.html>
- <https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/521-ccn-stic-811-interconexion-en-el-ens/file.html>
- <https://www.incibe.es/protege-tu-empresa/blog/dmz-y-te-puede-ayudar-proteger-tu-empresa>
- <https://www.ncsc.gov.uk/blog-post/drawing-good-architecture-diagrams>